# KCD SOC Incident Report: FRONTDESK-PC1 Compromise

## Findings

- **Timeframe:** 2025-10-15 12:51:44–13:04:59 UTC
- **Host:** FRONTDESK-PC1 (172.16.0.110)
- **Compromised Account:** Ryan.Adams (Local Administrator)
- **Attacker Source:** 172.16.0.184 (DESKTOP-924H12)
- **C2:** 157.245.46.190:8888, 9999 (AS14061, DigitalOcean, London, UK)
- **C2 Domain:** kajsdiqwe[.]icu
- **C2 Framework:** Sliver
- **Threat Type:** botnet_cc
- **Payload:** python.exe
- **Payload Path:** C:\Users\Ryan.Adams\Music\python.exe
- **Payload SHA256:** CFFAB896E9F0B12101034D9CED76332EF5AA4036AFA08E940E825E277C21A044
- **Persistence:** Scheduled Task “PythonUpdate” (onstart /ru SYSTEM)
- **Lateral Movement Target:** 172.16.0.7 (Ports 135, 49669)

## Investigation Summary

The investigation was initiated after Ryan Adams, a local administrator at Kerning City Dental (KCD), reported unauthorized mouse movement on FRONTDESK-PC1 at approximately 13:00 UTC on October 15, 2025, indicating potential remote access or system compromise.

Analysis determined that the incident began at 12:51:44 UTC, when an attacker from 172[.]16[.]0[.]184 (DESKTOP-924H12) conducted a password spraying attack targeting multiple accounts (administrator, guest, andrew.henderson, ryan.adams), generating 157 failed authentication attempts within 73 seconds. At 12:52:12 UTC, the attacker successfully authenticated using the KCD\Ryan.Adams account via NTLM network logon (Type 3) and was immediately granted administrative privileges, providing full control of the system. The attacker then disabled Microsoft Defender Real-Time Protection at 12:55:50 UTC, followed by downloading a malicious payload (python.exe) via chrome.exe at 12:57:00 UTC to a user-writable directory (C:\Users\Ryan.Adams\Music\). The payload was executed at 13:00:33 UTC, establishing command-and-control (C2) communication with 157[.]245[.]46[.]190 over ports 8888 and 9999. Threat intelligence analysis using VirusTotal and AbuseIPDB confirmed the IP as malicious, with multiple detections and abuse reports associated with Sliver C2 infrastructure hosted on DigitalOcean (AS14061) in London, United Kingdom.

Post-exploitation activity included interactive PowerShell sessions, indicating hands-on keyboard control, and the creation of a scheduled task (**PythonUpdate**) at 13:04:59 UTC to maintain persistence. The compromised host also initiated RPC connections to 172[.]16[.]0[.]7, consistent with attempted lateral movement; however, no successful spread was observed.

All malicious activity occurred between 12:51:44 and 13:04:59 UTC and involved the compromised account KCD\Ryan.Adams and host FRONTDESK-PC1. No additional attacker activity was observed beyond this timeframe; however, persistence mechanisms remained in place, and the host should be considered at risk until containment actions are completed.

The incident was enabled by environmental weaknesses, including a lack of account lockout controls, the use of NTLM authentication, and the absence of application control, which allowed execution from a user-writable directory. No evidence of lateral movement, credential reuse, or compromise of additional systems was identified. Additionally, no evidence of patient data access, modification, or exfiltration was observed during the intrusion.

## Who, What, When, Where, Why, How

## Who

- **Victim:** Ryan Adams (KCD\Ryan.Adams)
- **Victim Host:** FRONTDESK-PC1 (172.16.0.110)
- **Attacker Source:** 172.16.0.184 (DESKTOP-924H12)
- **Attacker C2:** 157.245.46.190
- **Other Targeted Accounts:** administrator, guest, andrew.henderson
- **Lateral Movement Target:** 172.16.0.7

## What

- The investigation confirmed that FRONTDESK-PC1 was compromised following a password spraying attack against the Ryan.Adams account.
- The attacker successfully authenticated via NTLM, obtained administrative privileges, and disabled Microsoft Defender to evade detection.
- A malicious payload (python.exe) was then downloaded via Chrome into a user directory and executed, providing the attacker with interactive access to the system.
- Persistence was established through a scheduled task configured to execute the payload at system startup.
- The compromised host subsequently communicated with an external command-and-control (C2) server associated with Sliver malware.
- The attacker attempted internal network access via RPC; however, no evidence of successful lateral movement or spread to other systems was observed.

## When

**Date Range**: October 15, 2025 — 12:51:44 to 13:04:59 UTC
**Status:** Compromise remains active pending containment. Persistence mechanism and C2 channel are still in place; however, no additional activity was observed after 13:04:59 UTC.

## Key Timestamps

- **12:51:44 – 12:52:12** — Password spraying attack from **172.16.0.184** targeting multiple accounts
- **12:52:12** — Successful NTLM authentication (**KCD\Ryan.Adams**, Logon Type 3)
- **12:52:12 – 12:55:17** — Administrative privileges assigned (**EventCode 4672**, full system-level access obtained)
- **12:55:50** — Microsoft Defender Real-Time Protection disabled (**EventCode 5001**)
- **12:57:00** — Malicious payload (python.exe) written to disk via **chrome.exe**
- **12:59:20 – 13:00:40** — Initial C2 communication established with **157.245.46.190**
- **13:00:33** — Payload execution (python.exe) from user directory
- **13:00:44 – 13:04:54** — Interactive PowerShell activity (attacker hands-on-keyboard behavior)
- **13:04:59** — Scheduled task **"PythonUpdate"** created via schtasks.exe (persistence established as SYSTEM)

See Appendix for full attack timeline.

## Where

- **Affected Host:** FRONTDESK-PC1 (172.16.0.110)
- **Compromised Account:** KCD\Ryan.Adams (Local Administrator)
- **Attack Source:** 172.16.0.184 (DESKTOP-924H12)
- **External C2:** 157.245.46.190 (DigitalOcean)
- **Other Targeted Accounts:** administrator, guest, andrew.henderson (identified during password spraying activity)
- **Lateral Movement Target:** 172.16.0.7

## Scope of Impact

- Compromise was contained to **FRONTDESK-PC1**
- No evidence of:
    - Lateral movement to additional hosts
    - Credential reuse on other systems
    - Malware execution outside the affected endpoint

## Internal Network Activity

- FRONTDESK-PC1 initiated RPC communication to **172.16.0.7** (port 135)
- Activity is consistent with reconnaissance or attempted lateral movement
- No successful authentication or remote execution was observed

## Why

### Intent:

Activity indicates a goal of **persistent remote access** to the compromised system. PowerShell interaction, C2 communication, and scheduled task creation demonstrate **hands-on-keyboard control** and intent for **long-term access**, rather than automated or opportunistic execution. No evidence of data exfiltration or ransomware was observed. The objective was sustained system access and control for potential follow-on activity.

### Root Cause:

- No account lockout policy — **157 failed attempts** without triggering a lockout
- Compromised account (**Ryan.Adams**) had **local administrator privileges**
- NTLM authentication enabled remote access from **172.16.0.184**
- No application control — binary executed from a **user-writable directory**
- Microsoft Defender lacked effective tamper protection — **Real-Time Protection disabled prior to payload execution**

## How

- The attacker performed a password spraying attack from **172[.]16[.]0[.]184**, targeting multiple accounts within a short time window.
- A successful NTLM network logon (**Logon Type 3**) was achieved using **KCD\Ryan.Adams**, granting initial access to the system.
- The compromised account had local administrator privileges, allowing immediate elevation and full control of the endpoint.
- Microsoft Defender Real-Time Protection was disabled shortly after access under SYSTEM context, reducing detection capability before payload delivery.
- The attacker downloaded a malicious binary using **chrome[.]exe**, saving it to a user-writable directory:

  ```
  C:\Users\Ryan.Adams\Music\python.exe
  ```

- The payload (**python.exe**) was executed, establishing an initial foothold on the system.
- The compromised host communicated with **157[.]245[.]46[.]190** over ports **8888** and **9999**, consistent with command-and-control (C2) activity.
- The attacker launched PowerShell and interacted with the system, indicating hands-on-keyboard post-exploitation activity.
- A scheduled task (**PythonUpdate**) was created to execute the payload as SYSTEM at startup, establishing persistence.

- The compromised host initiated RPC communication with **172[.]16[.]0[.]7** (port 135), consistent with reconnaissance or attempted lateral movement.

# Recommendations

## Immediate (0–24 hours)

- Isolate **FRONTDESK-PC1** from the network to prevent further attacker activity
- Reset credentials for **Ryan.Adams** and revoke all active sessions
- Remove persistence:
  - Delete scheduled task **PythonUpdate**
  - Remove malicious file:
    C:\Users\Ryan.Adams\Music\python.exe
- Block malicious infrastructure:
  - 157[.]245[.]46[.]190 (C2 server)
  - 172[.]16[.]0[.]184 (attack source)
  - kajsdiqwe[.]icu (malicious domain)
- Re-enable Microsoft Defender Real-Time Protection and validate protection status
- Investigate **172[.]16[.]0[.]7** for lateral movement or compromise indicators

## Short-Term (1–7 days)

- Implement account lockout policies to prevent password spraying
- Enforce application control (AppLocker / WDAC) to block execution from user-writable directories
- Reduce NTLM usage and enforce Kerberos authentication where possible
- Perform an IOC sweep across the environment:
  - IP: 157[.]245[.]46[.]190
  - Domain: kajsdiqwe[.]icu
  - File: python.exe (hash-based if available)
- Verify and update audit policy to ensure **scheduled task creation (EventCode 4698)** is logged

## Long-Term (30–90 days)

- Enforce Multi-Factor Authentication (MFA) for all administrative accounts
- Deploy Endpoint Detection and Response (EDR) with tamper protection
- Enhance centralized logging and monitoring (authentication, process, and network telemetry)
- Conduct a security architecture review focusing on:
  - Privileged access management
  - Network segmentation
  - Endpoint hardening

# Attack Timeline

| Time (UTC) | Event |
|---|---|
| **10-15-25 12:51:44** | Password spraying begins from 172[.]16[.]0[.]184 targeting administrator, guest, andrew.henderson, and ryan.adams |
| **10-15-25 12:52:12** | Successful NTLM logon (Type 3) — Ryan.Adams compromised |
| **10-15-25 12:52:12** | Administrative privileges assigned (SeDebugPrivilege, SeImpersonatePrivilege, SeBackupPrivilege, SeRestorePrivilege, SeTakeOwnershipPrivilege, SeLoadDriverPrivilege, SeSecurityPrivilege) |
| **10-15-25 12:52:54** | Additional successful logon confirms stable access |
| **10-15-25 12:52:57** | Password spraying ends (157 failed attempts observed) |
| **10-15-25 12:54:29** | sc.exe service interaction observed under SYSTEM context |
| **10-15-25 12:55:17** | New session created (interactive context established) |
| **10-15-25 12:55:50** | Microsoft Defender Real-Time Protection was disabled under the SYSTEM context |
| **10-15-25 12:56:30** | Chrome creates a temporary download file (payload staging) |
| **10-15-25 12:57:00** | Malicious binary written: C:\Users\Ryan.Adams\Music\python.exe |
| **10-15-25 12:59:20** | Initial outbound connection to 157[.]245[.]46[.]190:9999 |
| **10-15-25 13:00:33** | Malicious binary (python.exe) executed from the user directory |
| **10-15-25 13:00:34** | Command-and-control communication to 157[.]245[.]46[.]190:8888 |
| **10-15-25 13:00:34** | RPC connection initiated to 172[.]16[.]0[.]7:135 (lateral movement attempt) |
| **10-15-25 13:00:44** | PowerShell launched, indicating interactive attacker activity |
| **10-15-25 13:02:14** | Task Scheduler accessed via mmc.exe (pre-persistence activity) |
| **10-15-25 13:03:57** | Continued PowerShell activity (hands-on keyboard control) |
| **10-15-25 13:04:59** | Scheduled task "PythonUpdate" created to execute payload as SYSTEM at startup |

## Attack Metrics

- **Attack Duration:** 13 minutes 15 seconds
  *(12:51:44 – 13:04:59)*
  → Time from initial attacker activity to persistence establishment
- **Dwell Time:** ~8 minutes
  *(12:52:12 – ~13:00)*
  → Time from successful compromise to detection by the user

## Detection

| Time (UTC) | Event |
|---|---|
| **~10-15-25 13:00** | Ryan Adams reports suspicious mouse movement to SOC hotline |

## MITRE ATT&CK Mapping

| Tactic | Technique | ID | Evidence |
|---|---|---|---|
| **Initial Access** | Password Spraying | T1110.003 | 157 failed authentication attempts from 172[.]16[.]0[.]184 across multiple accounts within 73 seconds |
| **Initial Access** | Valid Accounts | T1078.002 | Successful NTLM logon (Type 3) using compromised account Ryan.Adams from 172[.]16[.]0[.]184 |
| **Execution** | User Execution | T1204 | Malicious binary python.exe executed from a user-writable directory |
| **Execution** | Command and Scripting Interpreter (PowerShell) | T1059.001 | Interactive PowerShell sessions observed post-compromise |
| **Persistence** | Scheduled Task | T1053.005 | Scheduled task **PythonUpdate** created to execute payload as SYSTEM at startup |
| **Defense Evasion** | Impair Defenses | T1562.001 | Microsoft Defender Real-Time Protection disabled under SYSTEM context (EventCode 5001) |
| **Defense Evasion** | Masquerading | T1036 | Payload named python.exe stored in non-standard path: C:\Users\Ryan.Adams\Music\ |
| **Command and Control** | Ingress Tool Transfer | T1105 | Payload downloaded via Chrome from external IP 157[.]245[.]46[.]190 |
| **Command and Control** | Application Layer Protocol | T1071 | C2 communication over TCP ports 8888 and 9999 using direct IP (no DNS) |
| **Discovery** | Remote System Discovery | T1018 | Internal RPC probing to 172[.]16[.]0[.]7 (port 135) |
| **Lateral Movement** | Remote Services | T1021 | RPC connections to 172[.]16[.]0[.]7 (ports 135, 49669); no successful movement observed |

**8 tactics, 11 techniques observed.**

## MITRE D3FEND Countermeasures

| D3FEND Tactic | D3FEND Technique | How It Applies |
|---|---|---|
| **Harden** | Multi-factor Authentication (D3-MFA) | Prevents credential-only access even if password is compromised |
| **Harden** | Strong Password Policy (D3-SPP) | Reduces likelihood of password spray success |
| **Detect** | Authentication Event Thresholding (D3-AET) | Alerts on high-volume failed logon attempts from single source |
| **Evict** | Account Locking (D3-AL) | Locks account after failed attempt threshold — was not configured |
| **Detect** | Domain Account Monitoring (D3-DAM) | Monitors for anomalous account usage patterns |
| **Isolate** | User Account Permissions (D3-UAP) | Restricts admin privileges to least-privilege model |
| **Detect** | System Daemon Monitoring (D3-SDM) | Detects unauthorized changes to security services |
| **Harden** | System Configuration Permissions (D3-SCP) | Prevents unauthorized modification of security tool settings |
| **Detect** | File Hashing (D3-FH) | Identifies known-bad binaries by hash comparison |
| **Isolate** | Executable Allowlisting (D3-EAL) | Blocks execution of unsigned binaries from non-standard paths |
| **Isolate** | Executable Allowlisting (D3-EAL) | Prevents execution from user-writable directories |
| **Detect** | Process Spawn Analysis (D3-PSA) | Detects suspicious parent-child process relationships |
| **Detect** | Script Execution Analysis (D3-SEA) | Monitors and analyzes PowerShell script execution |
| **Detect** | Scheduled Job Analysis (D3-SJA) | Detects creation of suspicious scheduled tasks |
| **Detect** | Network Traffic Signature Analysis (D3-NTSA) | Identifies executable downloads via IDS signatures |
| **Isolate** | Outbound Traffic Filtering (D3-OTF) | Blocks connections to known malicious infrastructure |
| **Detect** | Protocol Metadata Anomaly Detection (D3-PMAD) | Detects non-standard protocol usage on common ports |
| **Isolate** | Outbound Traffic Filtering (D3-OTF) | Restricts outbound connections to approved destinations |
| **Detect** | RPC Traffic Analysis (D3-RTA) | Monitors internal RPC traffic for reconnaissance patterns |
| **Isolate** | Broadcast Domain Isolation (D3-BDI) | Network segmentation limits lateral movement paths |
| **Detect** | Remote Terminal Session Detection (D3-RTSD) | Identifies unauthorized remote service connections |

# KQL Queries

## 01 — Password Spray & Successful Logon

```
index="mydfir-lab1" EventCode=4624 OR EventCode=4625 NOT Account_Name="*$*"
| stats count min(_time) as first_seen max(_time) as last_seen by Account_Name Logon_Type EventCode
Source_Network_Address Workstation_Name Authentication_Package
| convert ctime(first_seen) ctime(last_seen)
| table first_seen last_seen Account_Name EventCode Logon_Type Source_Network_Address Workstation_Name
Authentication_Package count
| sort +first_seen
```

## 02 — Privilege Escalation

```
index="mydfir-lab1" host="FRONTDESK-PC1" EventCode=4672
| search Subject_Account_Name="Ryan.Adams"
| table _time Subject_Account_Name Subject_Logon_ID Privileges
| sort +_time
```

## 03 — Defender Disabled

```
index="mydfir-lab1" host="FRONTDESK-PC1" sourcetype="WinEvent:Defender"
| search EventCode IN (5001, 5007)
| table _time EventCode User Message
| sort +_time
```

## 04 — Payload Delivery

```
index="mydfir-lab1" host="FRONTDESK-PC1" EventCode=11
| search TargetFilename="*python.exe"
| table _time Image TargetFilename User ProcessGuid
| sort +_time
```

## 05 — Payload Execution

```
index="mydfir-lab1" host="FRONTDESK-PC1" EventCode=1
| search Image="*\\Users\\Ryan.Adams\\Music\\python.exe"
| table _time Image CommandLine ParentImage User
| sort +_time
```

## 06 — C2 Communication

```
index="mydfir-lab1" host="FRONTDESK-PC1" EventCode=3
| search DestinationIp="157.245.46.190" OR DestinationIp="172.16.0.7"
| table _time Image SourceIp SourcePort DestinationIp DestinationPort
| sort +_time
```

## 07 — Suricata IDS Alerts

```
index="mydfir-lab1" host="FRONTDESK-PC1" sourcetype=suricata
| search dest_ip="157.245.46.190"
| stats count min(_time) as first_seen max(_time) as last_seen values(dest_port) as ports by src_ip dest_ip
| convert ctime(first_seen) ctime(last_seen)
| table first_seen last_seen src_ip dest_ip ports count
```

## 08 — Persistence

```
index="mydfir-lab1" host="FRONTDESK-PC1" EventCode=1 Image="*schtasks.exe"
| table _time User CommandLine ParentImage
| sort +_time
```

## 09 — Lateral Movement Validation

```
index="mydfir-lab1"
| eval indicator=case(
   Source_Network_Address="172.16.0.184","Attacker_IP",
   like(Account_Name,"%Ryan.Adams%"),"User_Activity",
   like(Image,"%python.exe"),"Malware",
   dest_ip="157.245.46.190","C2"
)
| where isnotnull(indicator)
| stats count by indicator host
| sort indicator
```

**10/11 — OSINT** Sources: VirusTotal (virustotal.com), AbuseIPDB (abuseipdb.com) IOC queried: 157[.]245[.]46[.]190